

Informe de auditoría · Core financiero de la COOPAC Santa Rosa

SI-084 · Auditoría de Sistemas · Examen práctico de Unidad I

Apellidos y nombres	Ancco Suaña, Bruno Enrique
Código de estudiante	2023077472
URL del repositorio	https://github.com/Brunoenr02/si084-caso-coopac/tree/examen-u1
Fecha	30/09/2026

1. Resultados de los procedimientos

Regla	Resultado, con cifras	¿Cumple?	Archivo de evidencia
R1	El contenedor <code>sr_bd</code> publica PostgreSQL en <code>0.0.0.0:55432 -> 5432/tcp</code> (y <code>[::]:55432</code>), exponiendo la base de datos a toda la red externa en el puerto 55432.	No	<code>evidencias/P1_puertos.txt</code>
R2	La contraseña del administrador está escrita en texto plano en <code>docker-compose.yml</code> (línea 10) y tiene solo 10 caracteres (<code>coopac2023</code>), incumpliendo el mínimo de 12 caracteres.	No	<code>evidencias/P2_credenciales.txt</code>
R3	Además de la cuenta administradora <code>postgres</code> , la cuenta <code>app_core</code> tiene asignado el atributo de Superuser, existiendo 2 superusuarios en el motor de base de datos.	No	<code>evidencias/P3_roles.txt</code>
R4	Se identificaron 16 cuentas activas pertenecientes a 10 personas cesadas (cese más antiguo: 18/12/2015). Además, existen 22 cuentas activas sin documento registrado (sin responsable), de las cuales 4 tienen perfil ADMIN.	No	<code>evidencias/P4_cesados.txt</code> · <code>evidencias/P4_genericas.txt</code>
R5	Con la condición <code>monto > umbral_aprobacion AND usuario_registra = usuario_aprueba</code> , se identificaron 23 desembolsos auto-aprobados que superan el umbral, por un monto total de S/ 709,370.47, registrados por 21 usuarios distintos.	No	<code>evidencias/P5_segregacion.txt</code>
R6	Los parámetros <code>log_connections = off</code> y <code>log_statement = none</code> están deshabilitados (configurados en la línea 11 de <code>docker-compose.yml</code>); para cumplir R6 deberían ser <code>on</code> y <code>mod</code> .	No	<code>evidencias/P6_registro.txt</code>
R7	El último respaldo exitoso data del 14/11/2025, acumulando 47 días sin respaldo hasta el 31/12/2025 (por error 'No space left on device' en <code>respaldo.log</code>). En la base restaurada falta la tabla <code>desembolsos</code> (excluida en <code>respaldo.sh</code>).	No	<code>evidencias/P7_respalDOS.txt</code> · <code>evidencias/P7_restauracion.txt</code>

2. Hallazgo 1

Elemento	Contenido
Título	Interrupción de respaldos del core financiero durante 47 días y exclusión deliberada de la tabla crítica de desembolsos
Condición	Se verificó que el último respaldo generado data del 14/11/2025 (<code>core_2025-11-14.sql</code>), acumulando 47 días calendario consecutivos sin generación de respaldos válidos hasta el corte del 31/12/2025. Asimismo, tras realizar la restauración en la base de datos <code>restauracion</code> , se constató que la tabla crítica <code>desembolsos</code> no existe en la base restaurada, conteniendo únicamente las tablas <code>empleados</code> y <code>usuarios</code> (2 tablas). Archivos de evidencia: <code>evidencias/P7_respaldos.txt</code> y <code>evidencias/P7_restauracion.txt</code> .
Criterio	Regla R7 de la Política de Seguridad del Core Financiero: «Respaldo diario completo, que incluye la tabla de desembolsos. Su restauración se prueba cada trimestre». Control de referencia: NTP-ISO/IEC 27001:2022 A.8.13 Respaldo de la información.
Causa	1) El script programado <code>respaldos/respaldo.sh</code> fue modificado el 01/11/2025 por el Jefe de Sistemas agregando la opción <code>--exclude-table=desembolsos</code> bajo el justificativo textual: «el respaldo tarda mucho; se excluye la tabla más pesada» (línea 3 de <code>respaldo.sh</code>). 2) El disco del servidor se saturó sin alertas operativas, generando errores diarios continuos de tipo <code>pg_dump: could not write to output file: No space left on device</code> desde el 15/11/2025 hasta el 31/12/2025 (constatado en <code>respaldos/respaldo.log</code>).
Efecto	Pérdida irrecuperable de hasta 47 días de información financiera y transaccional reciente ante caídas o corrupción del servidor. Imposibilidad total de recuperar el historial de créditos y desembolsos desde las copias de seguridad, provocando la paralización operativa de la entidad, contingencias patrimoniales por incobrabilidad y sanciones regulatorias severas por parte de la SBS por vulneración de la continuidad del negocio.
Recomendación	1) El Jefe de Sistemas debe modificar de inmediato <code>respaldos/respaldo.sh</code> suprimiendo la exclusión <code>--exclude-table=desembolsos</code> para asegurar el respaldo completo del core financiero. 2) El área de TI debe aprovisionar y ampliar el almacenamiento en disco, configurar políticas de retención/rotación y activar un sistema de monitoreo y alertas automáticas ante fallos en los respaldos o falta de espacio. 3) El Administrador de Base de Datos debe programar y documentar pruebas trimestrales obligatorias de restauración en un entorno de pruebas. Responsable: Jefe de Sistemas y Administrador de Base de Datos. Plazo: Inmediato (máximo 48 horas para habilitar espacio y corregir el script; 15 días calendario para formalizar el protocolo de monitoreo y restauración trimestral).

3. Hallazgo 2

Elemento	Contenido
Título	Auto-aprobación irregular de 23 desembolsos que superan el umbral de aprobación por S/ 709,370.47 por los mismos usuarios que los registraron
Condición	Se identificaron 23 desembolsos crediticios cuyo monto supera el umbral de aprobación fijado y que fueron aprobados por el mismo usuario que efectuó el registro (<code>monto > umbral_aprobacion AND usuario_registra = usuario_aprueba</code>), sumando un importe total comprometido de S/ 709,370.47. Dichas operaciones involucraron a 21 usuarios distintos de la cooperativa, destacando operaciones individuales de hasta S/ 161,160.52 (operación D00680). Archivo de evidencia: <code>evidencias/P5_segregacion.txt</code> .

Elemento	Contenido
Criterio	Regla R5 de la Política de Seguridad del Core Financiero: «Un desembolso que supera el umbral de aprobación no puede aprobarlo quien lo registró». Control de referencia: NTP-ISO/IEC 27001:2022 A.5.3 Segregación de funciones.
Causa	Carencia de validaciones en la capa de software del core financiero y ausencia de restricciones de integridad (constraints tipo CHECK o triggers de validación) en el motor de base de datos sobre la tabla <code>desembolsos</code> (conforme se observa en <code>bd/01_core.sql</code>), lo que permite persistir desembolsos donde <code>usuario_registra = usuario_aprueba</code> sin validar impositivamente si el monto excede el umbral fijado.
Efecto	Riesgo crítico de fraude financiero interno, colocaciones crediticias irregulares o apropiación indebida de fondos sin revisión independiente, generando una exposición y contingencia económica directa de S/ 709,370.47 en perjuicio del patrimonio de la cooperativa, además de observaciones y penalizaciones por parte de la SBS por debilidad material en el sistema de control interno.
Recomendación	1) El Jefe de Sistemas y el equipo de desarrollo deben implementar restricciones estrictas tanto en la lógica de la aplicación del core como a nivel de base de datos (mediante triggers o constraints) que impidan registrar o aprobar operaciones cuando el usuario aprobador coincida con el registrador si se supera el umbral. 2) La Gerencia de Riesgos y Auditoría Interna debe efectuar una auditoría forense especial a los 23 desembolsos observados para verificar la autenticidad de los expedientes, firmas y destino de los fondos. Responsable: Jefe de Sistemas (TI) y Auditor Interno / Gerencia de Riesgos. Plazo: Inmediato (5 días hábiles para el bloqueo en sistema y base de datos; 30 días calendario para la auditoría de los 23 expedientes de crédito).